Relatório de Viabilidade – Bloco 3

João Pedro Campolina Rodrigues

Repositório: github.com/joao-Devr/devsecops-trilha-joao-Pedro

Link no Render: https://devsecops-trilha-joao-pedro.onrender.com

Achados mais críticos e remediação

Trivy: A imagem base node:14 usa o Debian 10.13, que já não recebe atualizações de segurança, e fazia aparecer 566 vulnerabilidades CRITICAL/HIGH no sistema operacional. O Dockerfile também declarava USER non-root, um usuário que não existe na imagem. A correção foi migrar para node:24-slim (Debian 12) e usar USER node, o que reduziu o total para 35 vulnerabilidades, todas sem correção publicada pela distribuição.

Trivy: O Trivy apontou lodash 4.17.15 (4 achados) e jsonwebtoken 8.5.1 (1 achado), e tambem alguns pacotes internos do npm presentes na imagem (undici e brace-expansion). A correção foi atualizar lodash e jsonwebtoken para as versões mais recentes, commitar o package-lock.json e atualizar o npm da imagem (npm install -g npm@latest).

Gitleaks: Nenhum vazamento foi detectado, mas o arquivo config.js mantinha JWT_SECRET e chaves AWS em texto puro. Os valores eram de exemplo, e por isso o scanner os ignorou, mas se fosse valores reais ele ia detectar.

Deploy: O deploy ocorre somente pelo deploy hook, depois que todos os gates passam. Por usar o plano gratuito do render , o serviço hiberna após 15 minutos de inatividade e leva alguns segundos para responder à primeira requisição depois disso; esse comportamento é esperado. O endpoint /health permite verificar que a aplicação está no ar.